CYBERCRIME TYPE

RANSOMWARE

ABOUT THIS REPORT

This case study examines Ransomware — one of the most financially devastating categories of cybercrime. Drawing on the landmark WannaCry attack of 2017, real statistical data from Cybersecurity Ventures, the FBI's Internet Crime Complaint Center (IC3), and peer-reviewed research, this report details the anatomy of the crime, the step-by-step mechanics of an attack, victim profiles, psychological and financial consequences, and evidence-based prevention strategies. The report is intended as an educational awareness resource for students, faculty, and the general public.

CRIME TYPE	INCIDENT	SCOPE	PREPARED BY
Ransomware / Malware	**WannaCry Global Attack (2017)**	**150 Countries, 200,000+**	**SystemDsigital Ambassador**

Case Study By
Amit Kumar
25MIP10124

"Cybercrime is a shadow industry that costs the world trillions each year."
— Cybersecurity Ventures, 2023 Cybercrime Report

What is ransomware?

Ransomware is a category of malicious software — malware — designed to deny a victim access to their own data, systems, or devices until a ransom payment is made, typically in a hard-to-trace cryptocurrency such as Bitcoin. The attacker encrypts the victim's files using a sophisticated encryption algorithm, rendering them completely inaccessible, and then delivers a ransom note — either on-screen or via a dropped text file — demanding payment in exchange for a decryption key.

Unlike older forms of computer crime that merely stole data silently, ransomware is deliberately visible and confrontational. It exploits human fear and urgency. Victims are given countdown timers, threats to publish their private data online, and escalating ransom demands — all designed to maximise psychological pressure and increase the likelihood of payment.
Ransomware has evolved from a niche nuisance in the late 1980s to a trillion-dollar criminal ecosystem. In 2023, global ransomware damages were estimated at over USD 30 billion, and attacks now target hospitals, schools, government agencies, critical infrastructure, and multinational corporations with equal indiscrimination. The crime does not discriminate by geography: attacks have been recorded in over 180 countries.

> **"Every 11 seconds a business falls victim to a ransomware attack. By 2031, ransomware is predicted to cost its victims USD 265 billion annually." — Cybersecurity Ventures, 2022**

A Brief History of Ransomware

The first knownransomware— the AIDS Trojan, also called the PC Cyborg virus — was distributed on floppy disks by biologist Joseph Popp in 1989. It hid directory listings and encrypted filenames after 90 reboots, demanding USD 189 be mailed to a P.O. Box in Panama. While primitive by modern standards, it established the core criminal model that persists today.

Modern ransomware emerged around 2013 with CryptoLocker, which used RSA-2048 public-key cryptography and Bitcoin payments — making decryption genuinely impossible without the attacker's private key. From there, the threat landscape exploded. Ransomware-as-a-Service (RaaS) platforms emerged on the dark web by 2016, allowing virtually anyone to launch sophisticated attacks by licensing ready-made ransomware kits — no programming skill required.

GLOBAL IMPACT AT A GLANCE

$30B+
Estimatedglobalransomware damages in 2023

11 sec
Averagefrequency of a new ransomwareattack on businesses

66%
Oforganisations hit by ransomware in 2023(SophosState of Ransomware)

THAhPTEeR 0 2W — RaEAnL-WnORLaD ICNCIDrENyT Attack C (2017):

A Global Case Study

On 12 May 2017, a ransomware worm known as WannaCry — also called WannaCrypt or WanaCrypt0r 2.0 — began spreading across the internet at an unprecedented scale. Within 24 hours it had infected more than 230,000 computers across 150 countries. The attack crippled the United Kingdom's National Health Service (NHS), disrupted Spanish telecommunications giant Telefonica, shut down production lines at Renault and Nissan automobile factories, and paralysed government ministries in Russia, China, and Ukraine. Total damage estimates range from USD 4 billion to USD 8 billion.

What made WannaCry extraordinary was its use of EternalBlue — a cyberweapon developed by the United States National Security Agency (NSA) and leaked online just one month earlier by a group calling itself The Shadow Brokers. EternalBlue exploited a critical vulnerability (CVE-2017-0144) in Microsoft's SMB (Server Message Block) protocol, allowing the ransomware to spread automatically from one unpatched Windows machine to another on the same network, without any user interaction whatsoever. No one needed to click a link. No phishing email was required. The worm propagated entirely on its own.
Microsoft had actually released a patch (MS17-010) in March 2017 — two months before the attack. However, millions of organisations worldwide had not applied the update, either due to outdated IT infrastructure, budget constraints, or negligence. The NHS in particular was running thousands of computers on Windows XP — a version of Windows that Microsoft had stopped supporting in 2014 and for which no automatic patch was available.

NHS IMPACT — A SYSTEM IN CRISIS

The WannaCry attack forced 81 NHS trusts in England to cancel approximately 19,000 appointments and operations. Ambulances were diverted from affected hospitals. Staff reverted to pen and paper. A report by NHS England estimated the direct cost at GBP 92 million, with an additional GBP 72 million spent on IT recovery and upgrades in the aftermath. No patient deaths were directly attributed to the attack, though multiple investigations examined whether delayed care contributed to patient harm.

The attack was halted partly by luck. A cybersecurity researcher named Marcus Hutchins, while analysing WannaCry's code, discovered it contained a 'kill switch' — a domain name that, if registered, would cause the malware to deactivate. He registered the domain for USD 10.69, inadvertently stopping the spread of the worm worldwide. The UK's National Cyber Security Centre (NCSC), the FBI, and international intelligence agencies subsequently attributed the attack to the Lazarus Group — a state-sponsored hacking collective linked to the Democratic People's Republic of Korea (North Korea).

HHAo PTE w R 03 — R AT a TA n CK s ME o CHA m NICS ware Happens:

C

A Step-by-Step Breakdown

While WannaCry used a network worm propagation method, most ransomware attacks follow a more common seven-stage lifecycle known in cybersecurity as the 'ransomware kill chain.' Understanding each stage is essential for recognising — and interrupting — an attack before it reaches the encryption stage.

1

Initial Access — The Entry Point

Theattacker gains access to the target system. This is most commonly achieved through spear-phishing emails containing malicious attachments (weaponised Word documents, PDFs, or ZIP files) or malicious hyperlinks. Other vectors include Remote Desktop Protocol (RDP) brute-force attacks, exploitation of unpatched software vulnerabilities (as in WannaCry), drive-by downloads from compromised websites, and insider threats. Supply-chain attacks — where a trusted software vendor is compromised first — are an increasingly used advanced method.

2

Execution — Running the Payload

Onceinsidethe system,the malware executes its payload. It often uses 'living off the land' techniques — abusing legitimate system tools such as PowerShell, Windows Management Instrumentation (WMI), or PsExec to avoid detection by antivirus software. The malware may remain dormant for days or weeks — a period called 'dwell time' — before beginning encryption, so that even if the initial infection is noticed, backups may already be corrupted.

3

Privilege Escalation & Lateral Movement

Theattacker expands theirfoothold. They exploit local vulnerabilities to gain administrator or system-level privileges, then move laterally across the network — infecting file servers, database servers, backup systems, and cloud-connected storage. During this stage, the attacker maps the network and identifies the most valuable and sensitive data stores to maximise leverage.

4

Data Exfiltration (Double Extortion)

In modern ransomwareattacks, sensitive data is quietly stolen and uploaded to attacker-controlled servers BEFORE encryption begins. This enables 'double extortion' — even if the victim has backups and refuses to pay for decryption, the attacker threatens to publish or sell the stolen data on dark web leak sites. Notable ransomware groups operating leak sites include LockBit, BlackCat/ALPHV, and Clop.

5

Encryption — Files Become Hostages

The ransomwaredeploys its encryptionengine, systematically encrypting files across all accessible drives and network shares. Modern ransomware uses AES-256 for file encryption combined with RSA-2048 or elliptic-curve cryptography for key exchange — making brute-force decryption computationally impossible. The malware targets documents, images, databases, and backups while deliberately avoiding system files needed to keep the computer running and display the ransom note.

6

Ransom Demand Delivery

Aransom note appears on-screen, often replacing the desktop wallpaper. The note explains what has happened, provides a unique Bitcoin or Monero wallet address, and sets a deadline — typically 48 to 72 hours — after which the ransom amount increases or the decryption key is destroyed permanently. The note may include a 'proof of life' offer: decrypt one file for free to demonstrate the key works. Some ransomware groups operate professional customer service helplines and live chat portals on the dark web.

WHAPhTERo 04 —I s VIC TTIMSa & IrMPgACeTted &
C

What Are the Consequences?

Who Is Usually Targeted?

Ransomware operatorsselect targets based on three criteria: ability to pay, urgency of data access, and weakness of cyber defences. While early ransomware was indiscriminate — infecting any available machine — modern Ransomware-as-a-Service (RaaS) operations perform careful target reconnaissance and prioritise high-value victims.

Healthcare & Hospitals

Patientdatais irreplaceable andaccess istime-critical.Hospitalscannotaffordsystem downtime. Thecombination of life-or-death urgency and historically poor cybersecurity investment makes healthcare the single most targeted sector globally. In 2023, healthcare accounted for 18% of all ransomware victims (Sophos, 2023).

Government & Public Services

Governmentagencieshold sensitive citizen data and operate critical services. They often run legacy systems and face bureaucratic delays in applying security patches. Local and municipal governments — which lack federal-level cybersecurity budgets — are especially vulnerable.

Educational Institutions

Schools and universities manage vast personal data about students and staff, conduct valuable research, and operate with limited IT security budgets. Remote learning infrastructure introduced during the COVID-19 pandemic dramatically expanded the attack surface. In 2022, education was the most targeted sector in the UK (NCSC Annual Review 2022).

Small and Medium Businesses (SMBs)

SMBsareoftenseen as'soft targets'— they lack dedicated security teams, rarely conduct penetration testing, and may not have tested backup restoration procedures. 43% of all cyberattacks target small businesses (Accenture Cyber Threat Intelligence Report, 2021).

Critical Infrastructure

Energy, watertreatment, transportation, and communications infrastructure are increasingly targeted for maximum societal disruption. The 2021 Colonial Pipeline ransomware attack (by DarkSide group) caused fuel shortages across the US East Coast and demonstrated that ransomware can directly threaten national security.

Individual Users

Ordinary individuals are targeted through scattershot phishing campaigns. Home users typically face smaller ransom demands (USD 300 to USD 1,500) but suffer disproportionate emotional impact when personal photos, tax records, or family videos are encrypted. Elderly users and those with limited digital literacy are especially vulnerable.

Consequences: Financial

The financial impact ofransomware extends far beyond the ransom demand itself. According to IBM's Cost of a Data Breach Report 2023, the average total cost of a ransomware attack (including ransom payment, system restoration, legal fees, regulatory fines, and reputational damage) reached USD 5.13 million per incident. For large enterprises, these costs can reach hundreds of millions. The 2021 Colonial Pipeline attack resulted in a ransom payment of USD 4.4 million in Bitcoin (partially recovered by the US Department of Justice). Maersk shipping estimated its losses from the NotPetya ransomware attack at USD 300 million.

CHAPTER 04 (CONTINUED) — CONSEQUENCES

Consequences: Operational & Legal

Beyondfinances, ransomware causes severe operational disruption. Average downtime following a ransomware attack increased to 24 days in 2023 (Coveware, Q4 2023 Report). Healthcare providers reroute patients. Manufacturers halt production lines. Legal consequences include regulatory fines under GDPR (in Europe), HIPAA (in the US for healthcare), and India's DPDP Act 2023, if personal data is exfiltrated. Executives and boards face personal liability for failure to implement reasonable cybersecurity measures. In India, the Information Technology Act 2000 (as amended) imposes criminal liability for negligence leading to data breaches affecting third parties.

Consequences: Psychological & Social

For individuals, thepsychological impact of ransomware is severe. Victims report intense anxiety, helplessness, and feelings of violation akin to a physical burglary. The loss of irreplaceable personal data — family photographs, creative work, medical records — can cause lasting distress. For organisations, staff morale deteriorates, and public trust is deeply damaged. A 2022 survey by Keeper Security found that 65% of customers said they would lose trust in a company that experienced a ransomware-related data breach, regardless of whether the company paid the ransom.

HHo^A w^PT E t^R o^0 5 P ro^P te^RE c^V t^E N A^T g^IO a^N i^& n^R s^E t^S R^PO a^N n^SE somware

- **Patch and Update Systems Immediately**
  Thesinglemosteffectivedefence.WannaCryexploited a vulnerability for which a patch existed for two months. Organisations must implement automated patch management and treat critical security patches as emergency priorities.
- **Maintain Offline, Tested Backups**
  Followthe 3-2-1backup rule:3copies,on 2 different media, with 1 stored offline and air-gapped. Critically, test backup restoration regularly — ransomware actors specifically target and encrypt connected backup systems.
- **Enable Multi-Factor Authentication (MFA)**
  MFAonall remoteaccesspoints (especially RDP and VPN) prevents credential-based attacks. The majority of ransomware intrusions begin with stolen or brute-forced credentials.
- **Implement Network Segmentation**
  Dividenetworks so thatan infectionin one segment cannot spread freely. Critical systems should be isolated from general user networks. Limit lateral movement opportunities.
- **Train Staff in Phishing Recognition**
  Sincephishingremains theleading initial access vector, security awareness training must be ongoing and simulation-based. Staff should know how to report suspicious emails and understand that urgency in emails is a social engineering red flag.
- **Deploy Endpoint Detection & Response (EDR)**
  Modern EDRtools usebehaviouralanalysisto detect ransomware encryption activity in real time and can automatically isolate an infected machine — stopping spread before it begins.
- **Report to Authorities, Do Not Pay Silently**
  InIndia, report toCERT-In (cert-in.org.in) and theNational Cyber Crime Reporting Portal (cybercrime.gov.in). In the UK, report to NCSC and Action Fraud. In the US, report to the FBI's IC3 (ic3.gov). Paying the ransom is strongly discouraged by all law enforcement agencies.

Sources & References

[1] Cybersecurity Ventures (2022). Cybercrime To Cost The World USD 8 Trillion Annually In 2023. Cybersecurity Ventures Official Report. https://cybersecurityventures.com/cybercrime-damages/

[2] Sophos (2023). State of Ransomware 2023. Sophos Global Survey Report. https://www.sophos.com/en-us/content/state-of-ransomware

[3] IBM Security (2023). Cost of a Data Breach Report 2023. IBM Corporation. https://www.ibm.com/reports/data-breach

[4] NHS England & National Audit Office (2018). Investigation: WannaCry Cyber Attack and the NHS. National Audit Office Report HC 414, Session 2017-19. https://www.nao.org.uk/reports/digital-health/

[5] Symantec / Broadcom (2017). WannaCry: Ransomware Attacks Show Strong Connections to Lazarus Group. Symantec Threat Intelligence Blog. https://symantec-enterprise-blogs.security.com/blogs/threat-intelligence